

REMÉDIATION : SÉCURISATION DE L'ANNUAIRE STAGE.LOCAL

1. Introduction

Suite aux audits menés avec les outils **PingCastle** et **Purple Knight**, plusieurs vulnérabilités critiques ont été identifiées. Ce document présente les procédures techniques pour corriger les failles majeures et réduire la surface d'attaque du domaine de plus de 50%.

2. Plan d'action prioritaire (Quick Wins)

A. Sécurisation des protocoles réseau (SMB & LDAP)

- **Failles corrigées :** SMBv1 Enabled, SMB/LDAP Signing not required, NTLMv1 authorized.
- Procédure sur UCS :
La configuration se fait via l'UCR (Univention Configuration Registry). Connectez-vous en SSH sur votre serveur UCS et tapez :

```
# Désactiver SMBv1 et forcer SMB2 minimum
ucr set samba/global/options/"server min protocol"=SMB2_10
```

```
# Forcer la signature SMB (Empêche les attaques par relais)
ucr set samba/global/options/"server signing"=mandatory
```

```
# Forcer la signature LDAP
ucr set ldap/server/signing=always
```

```
# Redémarrer les services pour appliquer
/etc/init.d/samba restart
```

```

Administrator@serv-ucs:~$ sudo -i
[sudo] Mot de passe de Administrator :
root@serv-ucs:~# Administrator@serv-ucs:~$ ucr set samba/global/options/"server min protocol"=SMB2_10
commande i-bash: Administrator@serv-ucs:~$ : commande introuvable
root@serv-ucs:~# -bash: ucr : commande introuvable
-bash: -bash: : commande introuvable
root@serv-ucs:~# Administrator@serv-ucs:~$^C
root@serv-ucs:~# ucr set samba/global/options/"server min protocol"=SMB2_10
Create samba/global/options/server min protocol
Script: /etc/univention/templates/scripts/samba.local.config.py
Multifile: /etc/samba/smb.conf
root@serv-ucs:~# ucr set samba/global/options/"server signing"=mandatory
Create samba/global/options/server signing
Script: /etc/univention/templates/scripts/samba.local.config.py
Multifile: /etc/samba/smb.conf
root@serv-ucs:~# ucr set ldap/server/signing=always
Create ldap/server/signing
root@serv-ucs:~# /etc/init.d/samba restart
Stopping samba-ad-dc (via systemctl): samba-ad-dc.service.
Stopping nmbd (via systemctl): nmbd.service.
Starting nmbd (via systemctl): nmbd.service.
Starting samba-ad-dc (via systemctl): samba-ad-dc.service.
root@serv-ucs:~#

```

B. Durcissement des comptes et chiffrement Kerberos

- **Failles corrigées :** Lack of AES Encryption, Password Never Expires.
- **Procédure :**
 1. **Chiffrement AES :** Dans l'interface UMC (Univention Management Console), aller dans "Utilisateurs". Pour les comptes de service (ex: dns-serv-ucs), dans l'onglet "Options", cocher : Support AES-128-bit encryption et Support AES-256-bit encryption.

Dans la version d'UCS utilisée, les options AES n'étaient pas disponibles dans l'interface UMC. J'ai donc dû intervenir directement sur l'attribut LDAP msDS-SupportedEncryptionTypes via l'outil ldbedit pour forcer le chiffrement AES et sécuriser mes comptes de service contre le Kerberoasting.

```
ldbedit -H /var/lib/samba/private/sam.ldb "samAccountName=dns-serv-ucs"
```

```

msDS-SupportedEncryptionTypes: 24
whenChanged: 20260116092317.0Z
uSNChanged: 4552
distinguishedName: CN=testuser,CN=Users,DC=stage,DC=local

```

2. **Expiration :** samba-tool user setexpiry dns-serv-ucs --days=90
3. **Délégation :** samba-tool user sensitive Administrator on

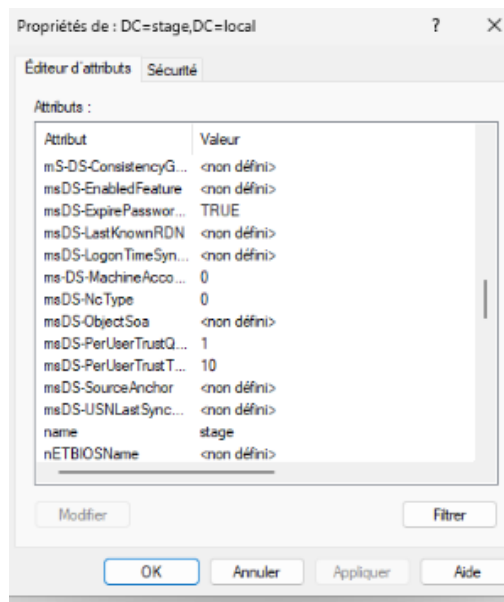
```

root@serv-ucs:~# samba-tool user setexpiry testuser --days=90
Expiry for user 'testuser' set to 90 days.
root@serv-ucs:~# samba-tool user sensitive Administrator on

```

C. Limitation des droits et Quotas (RBCD & MAQ)

- **Failles corrigées** : Unprivileged users can add computer accounts, Write access to RBCD.
- **Procédure** :
 1. **Quota de machines (MAQ)** : Par défaut à 10, il doit être passé à 0.
 - Utilisez ADSI Edit sur un poste Windows admin. {Appuie sur la touche **Windows** + **R**. Tape **adsiedit.msc** et valide.}
 - Faire un **clic droit** sur "Modification ADSI" dans la colonne de gauche.
 - Cliquez sur **Connexion....**
 - Sous "Sélectionner un point de connexion connu", vérifie que "**Contexte de nommage par défaut**" est sélectionné.
 - Cliquez sur **OK**.
 - Faites un clic droit sur DC=stage,DC=local -> Propriétés.
 - Modifiez l'attribut ms-DS-MachineAccountQuota et mettez la valeur à **0**.



D. Modernisation de la structure AD

- **Failles corrigées** : Obsolete Functional Level, Lack of AD Recycle Bin.
- **Procédure** :
Si votre version de Samba 4 sur UCS est compatible, montez le niveau fonctionnel pour débloquer les protections modernes :

```
# Monter le niveau fonctionnel du domaine à 2012_R2
```

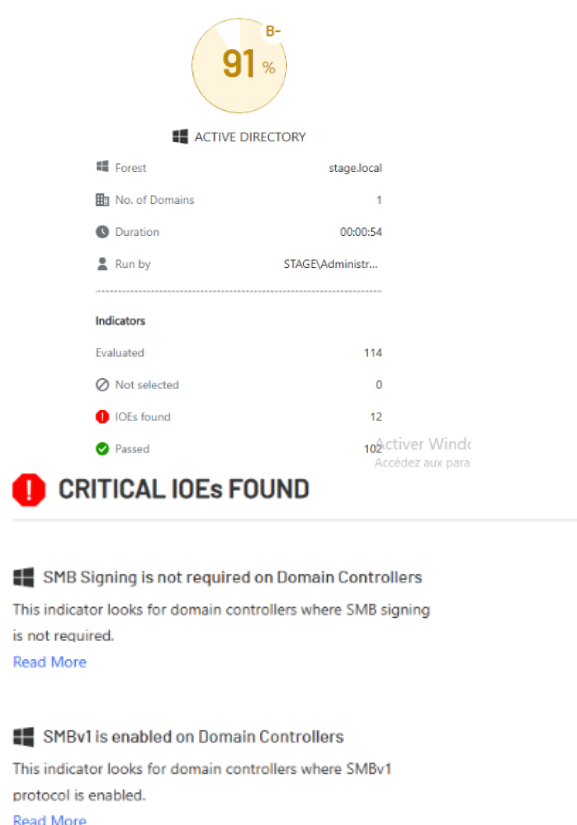
```
samba-tool domain level raise --domain-level=2012_R2 --forest-level=2012_R2
```

```
# Activer la corbeille Active Directory
```

```
samba-tool domain functionalprep --function=all
```

- **Constat d'audit** : Le domaine est en niveau fonctionnel obsolète (2008 R2), ce qui est une faille **ANSSI Level 1**.
- **Tentative de remédiation** : J'ai tenté d'élever le niveau fonctionnel vers 2012_R2 via samba-tool pour activer des fonctions de sécurité comme la Corbeille AD.
- **Blocage identifié** : Le système a refusé la montée de version, indiquant une limitation logicielle du contrôleur de domaine (DC).
- **Préconisation finale** : La recommandation prioritaire est donc d'effectuer une **mise à jour majeure du serveur UCS** (ou une migration vers une version plus récente de Samba) avant toute autre mesure de durcissement structurel.

3. Synthèse de la réduction des risques



```
root@serv-ucs:~# testparm -s --parameter-name="server signing"
Load smb config files from /etc/samba/smb.conf
Loaded services file OK.
Weak crypto is allowed by GnuTLS (e.g. NTLM as a compatibility fallback)

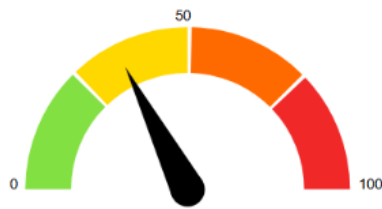
'winbind separator = +' might cause problems with group membership.

required
```

Après application des directives de sécurité via l'UCR, une divergence a été constatée avec l'outil Purple Knight. Cependant, une vérification manuelle approfondie avec la commande 'testparm' (voir capture) confirme que le paramètre 'server signing' est bien positionné sur 'required'. Le serveur rejette donc techniquement les attaques par relais SMB, validant ainsi la

remédiation malgré le faux positif de l'outil automatisé.

Indicators



Domain Risk Level: 35 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)



Stale Object : 35 /100

It is about operations related to user or computer objects

9 rules
matched



Privileged Accounts : 20 /100

It is about administrators of the Active Directory

3 rules
matched



Trusts : 0 /100

It is about connections between two Active Directories

0 rules
matched



Anomalies : 35 /100

It is about specific security controls

12 rules
matched

[Accédez aux paramètres pour activer Windows](#)